

API BUGS

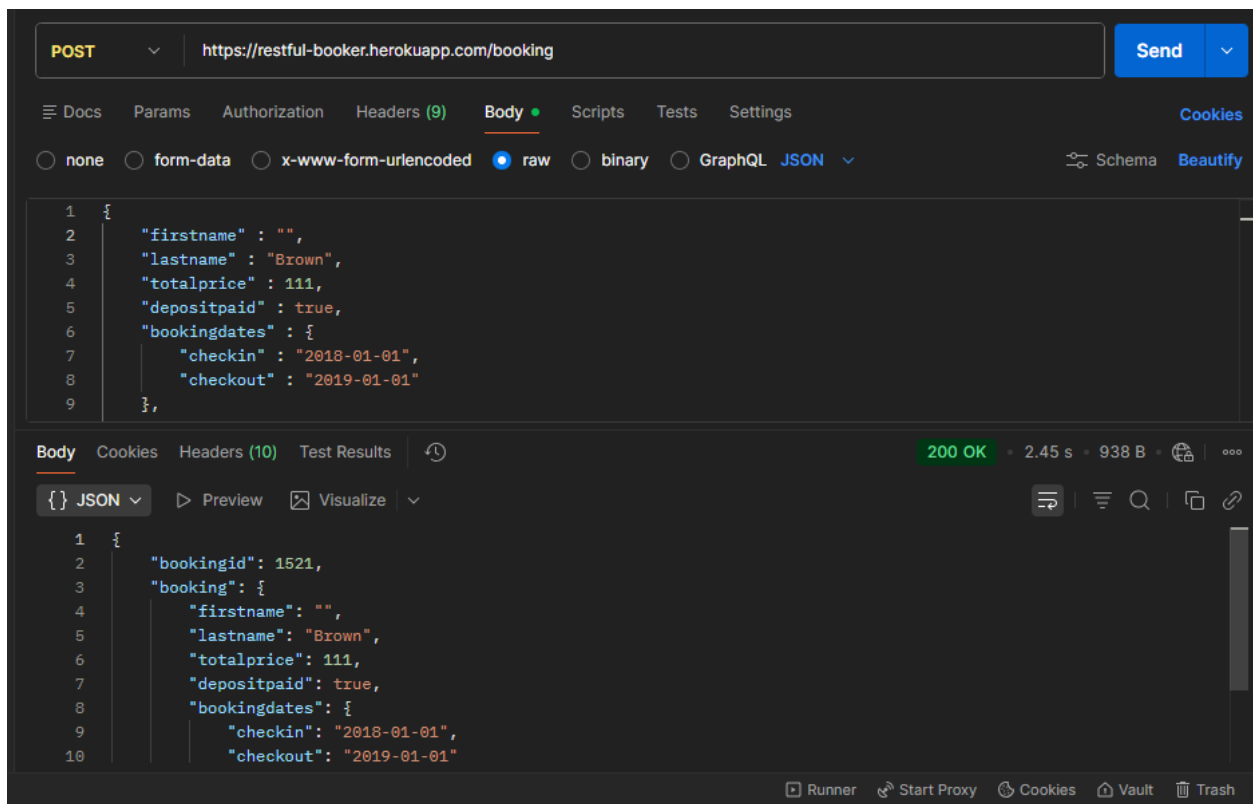
Create booking

#1)

Title : Empty firstname accepted without return status code 400 .

Steps : 1-send post / booking with firstname : " ".

Description : when I make post request to test api , I leave firstname field empty and the system accept It and return status code 200 and id .



Expected Result : API returns 400 Bad Request .

Actual Result : API returns 200 and creates booking with empty firstname .

Severity : high.

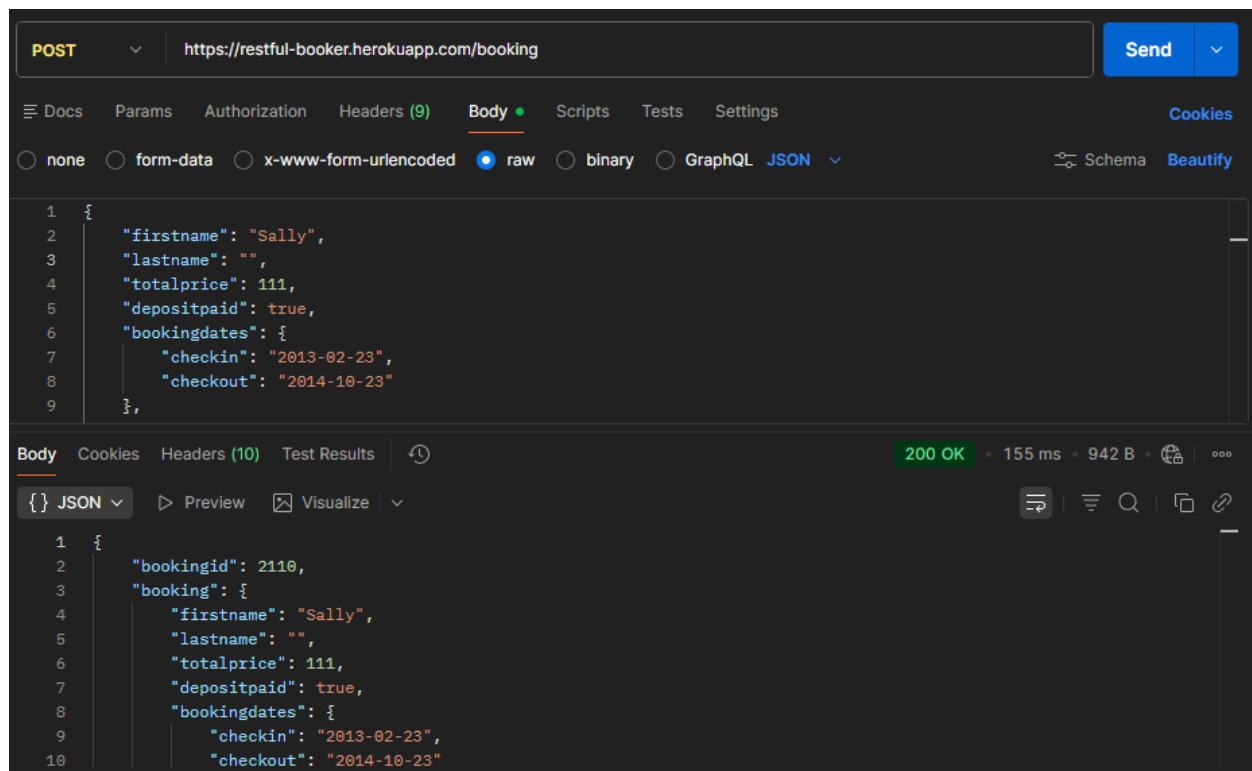
Priority :high.

#2)

Title : Empty lastname accepted without return status code 400 .

Steps : 1-send post / booking with lastname : " ".

Description : when I make post request to test api , I leave lastname field empty and the system accept It and return status code 200 and id .



Expected Result : API returns 400 Bad Request .

Actual Result : API returns 200 and creates booking with empty lastname .

Severity : high.

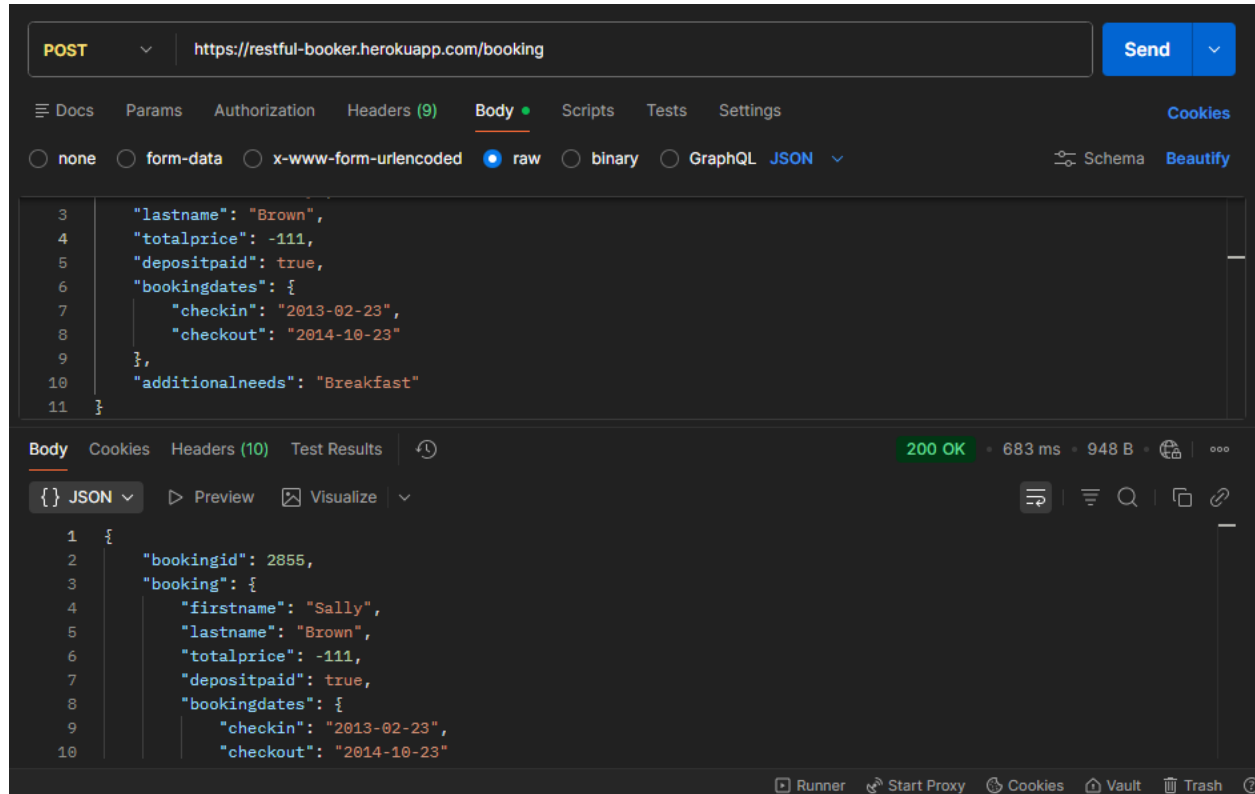
Priority :high.

#3)

Title : total price is negative and accepted without return status code 400 .

Steps : 1-send post / booking with total price : “ -111”.

Description : when I make post request to test api , I enterd total price field negative and the system accept It and return status code 200 and id .



Expected Result : API returns 400 Bad Request .

Actual Result : API returns 200 and creates booking with negative price .

Severity : medium .

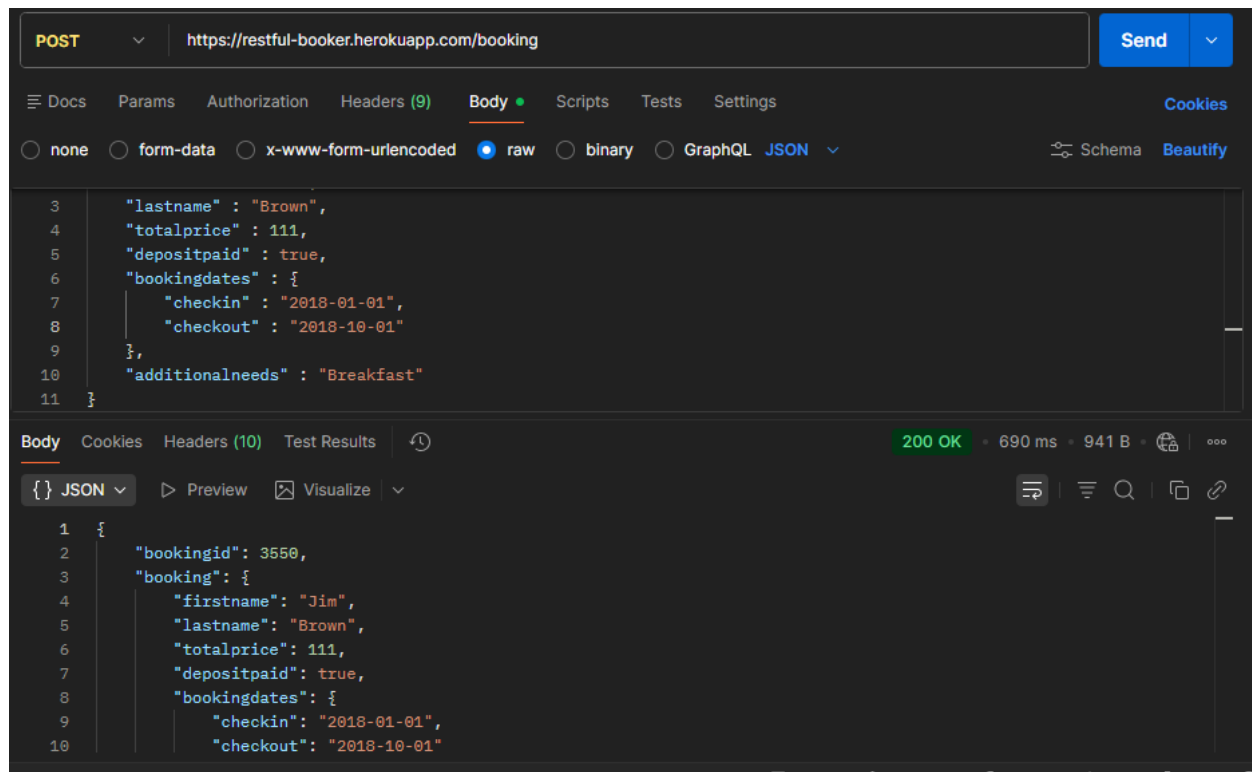
Priority : medium .

#4)

Title : check-out date is before check-in date and accepted without return status code 400 .

Steps : 1- Send POST with checkin: 2018-01-10, checkout: 2018-01-01 .

Description : when I make post request to test api , I enterd check-out date before check-in date and the system accept It and return status code 200 and id .



Expected Result : API returns 400 Bad Request .

Actual Result : API returns 200 and creates booking with check-out date before check-in date.

Severity : high.

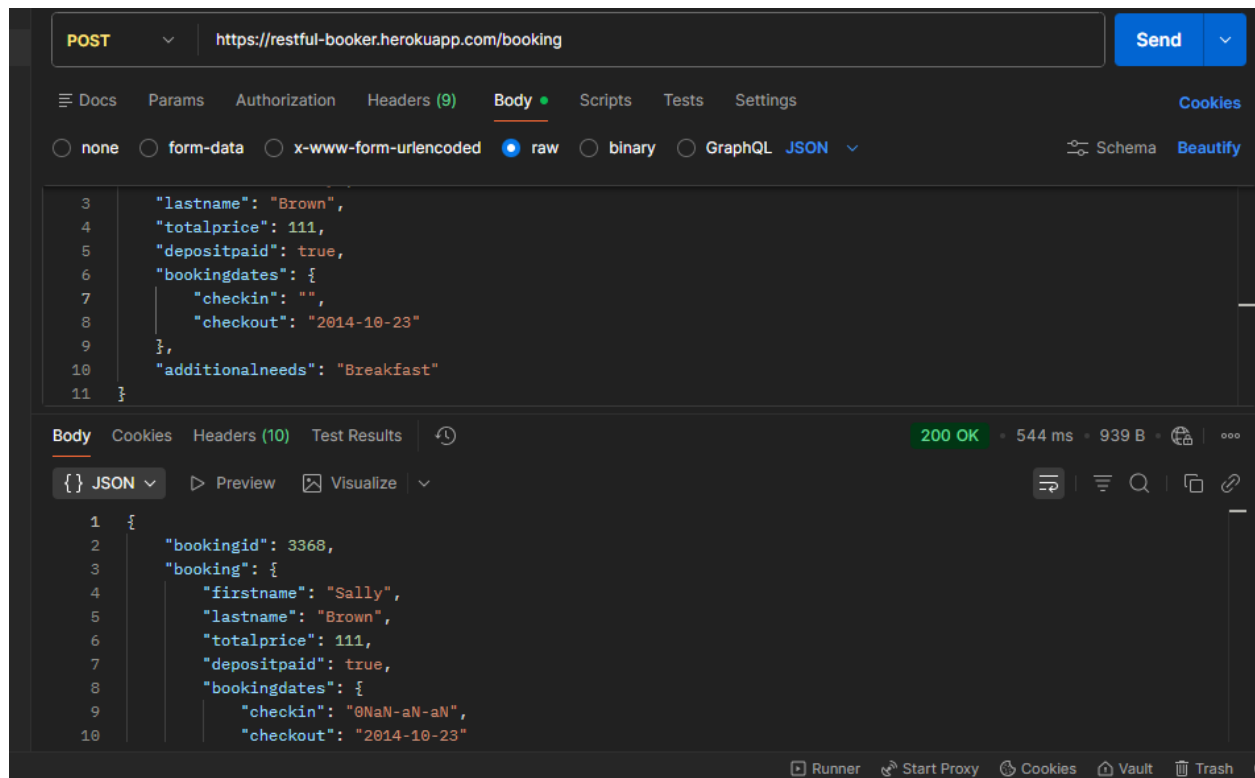
Priority : high.

#5)

Title : check-in date is empty and accepted without return status code 400 .

Steps : 1- Send POST /booking with check-in: " "

Description : when I make post request to test api , I leave check-in date empty and the system accept It and return status code 200 and id .



Expected Result : API returns 400 Bad Request .

Actual Result : API returns 200 and creates booking with check-in date empty.

Severity : high.

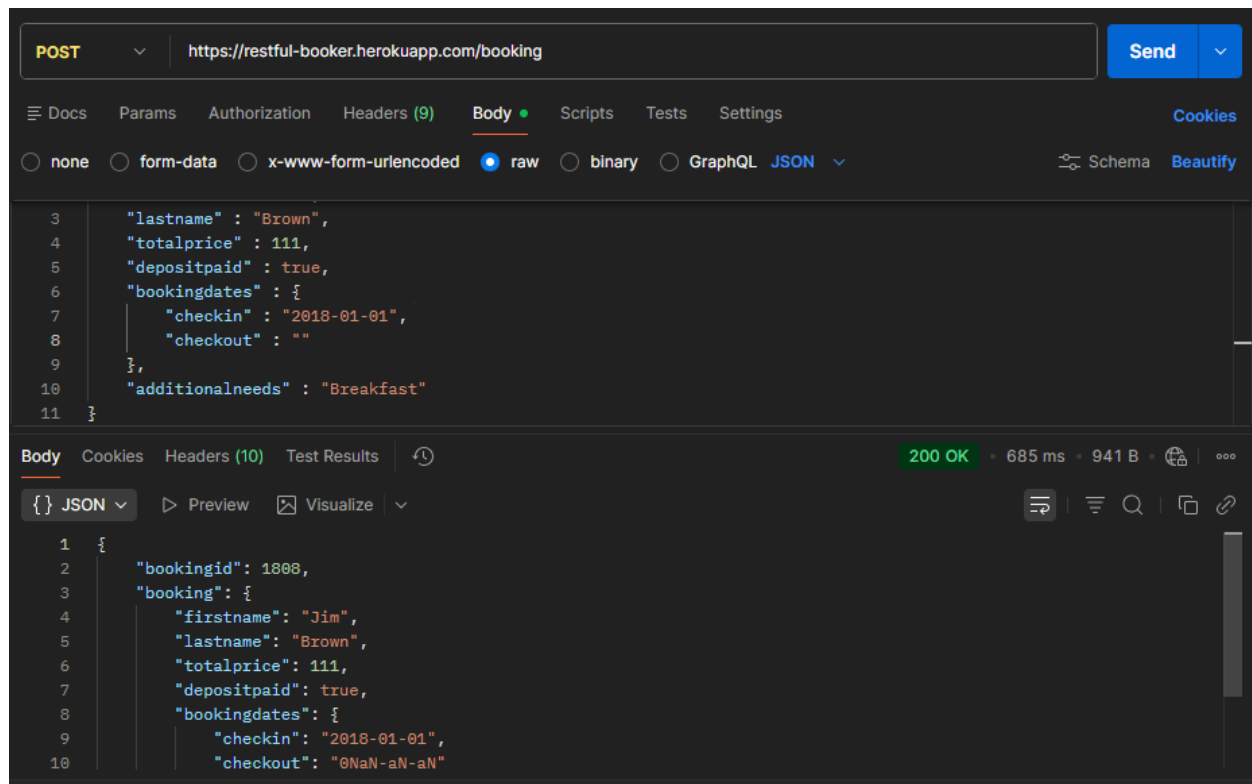
Priority : high.

#6)

Title : check-out date is empty and accepted without return status code 400.

Steps : 1- Send POST /booking with check-out: " "

Description : when I make post request to test api , I leave check-out date empty and the system accept It and return status code 200 and id .



Expected Result : API returns 400 Bad Request .

Actual Result : API returns 200 and creates booking with check-out date empty.

Severity : high.

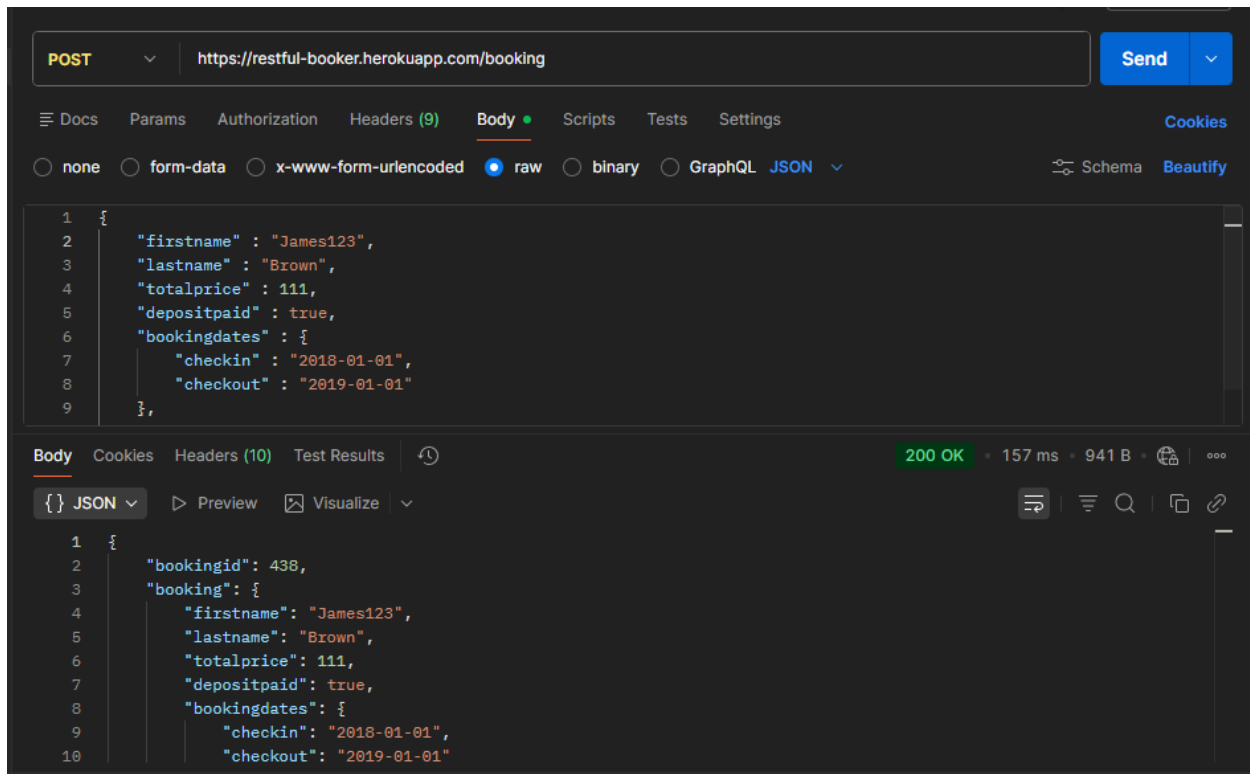
Priority : high.

#7)

Title : firstname with numbers accepted without return status code 400 .

Steps : 1-send post / booking with firstname : "james123 ".

Description : when I make post request to test api , I entered numbers at firstname field and the system accepted it and returned status code 200 and id .



Expected Result : API returns 400 Bad Request .

Actual Result : API returns 200 and creates booking id .

Severity : low

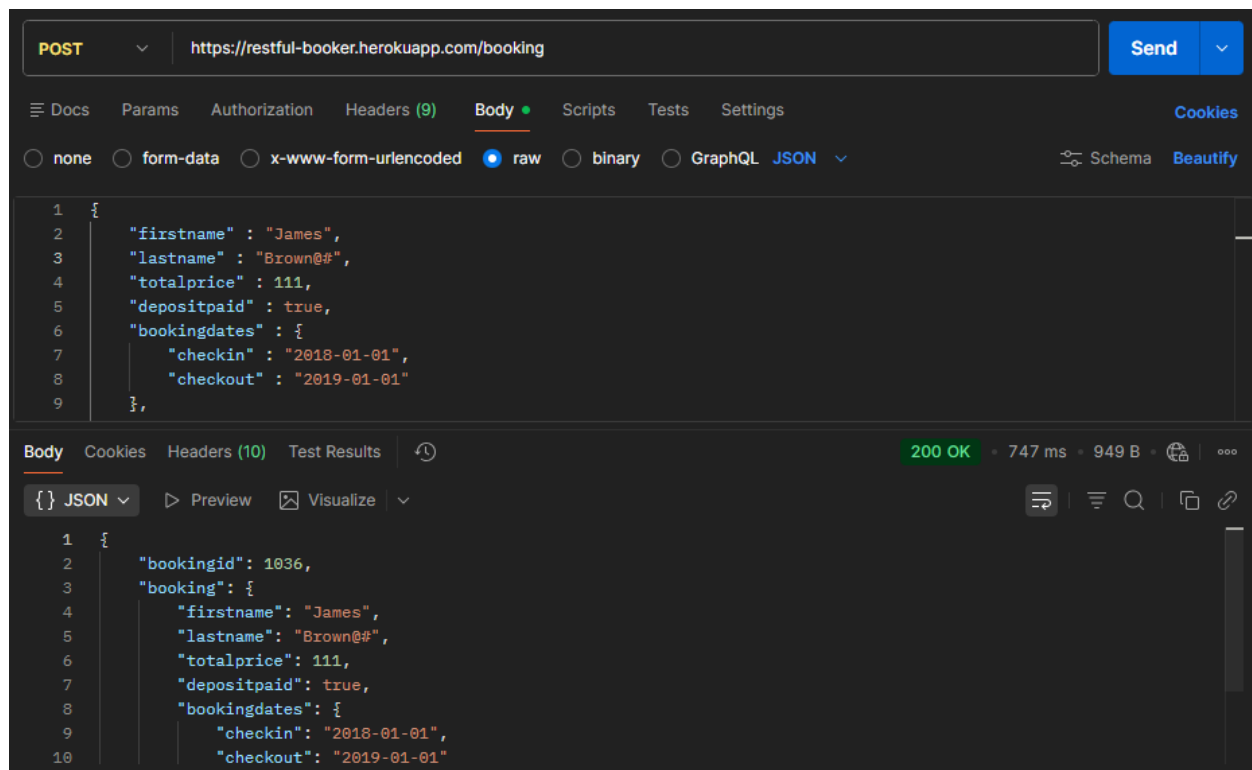
Priority : low

#8)

Title : Special chars in lastname accepted without return status code 400 .

Steps : 1-send post / booking with lastname : "brown@# ".

Description : when I make post request to test api , I entered special char at lastname field and the system accepted it and returned status code 200 and id .



Expected Result : API returns 400 Bad Request .

Actual Result : API returns 200 and creates booking id .

Severity : low

Priority : low

GET BOOKING

#1)

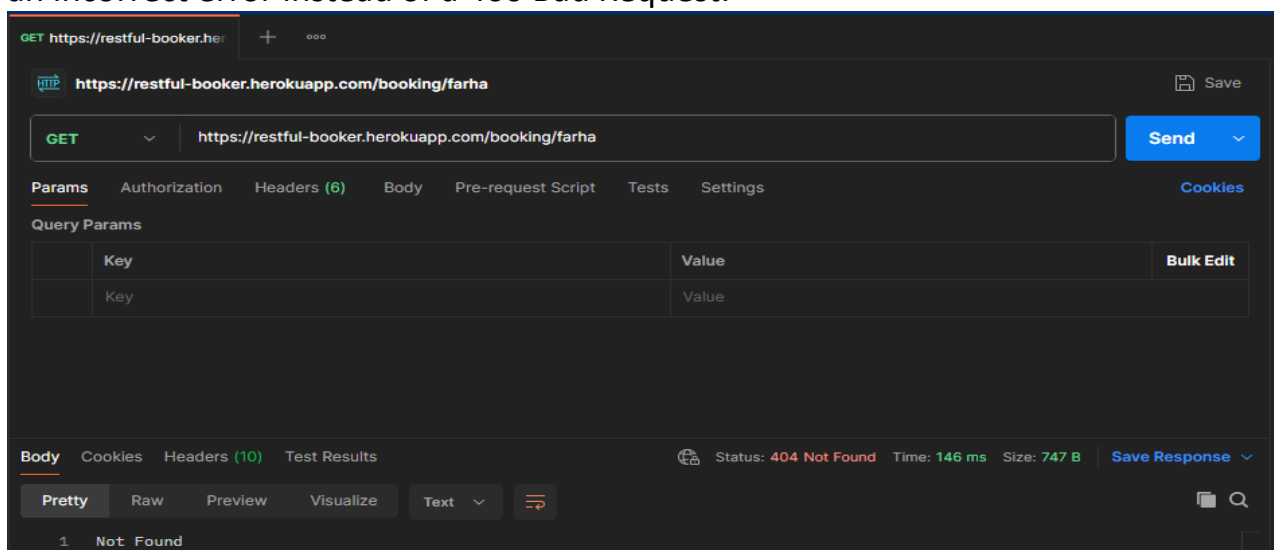
Title: Validate GetBooking API returns 400 Bad Request when booking ID is a string.

Steps:

- 1- Open Postman.
- 2- Set request method to GET.
- 3- Enter URL: `https://restful-booker.herokuapp.com/booking/abc` (Using a string instead of a number).
- 4- Click on the Send button.

Description:

When I make a GET request to retrieve a booking using a string (e.g., "abc") instead of a numeric ID, the system accepts it and returns status code 200 OK or an incorrect error instead of a 400 Bad Request.



Expected Result: API returns 400 Bad Request as status code and a validation error message.

Actual Result: API returns 200 OK (or doesn't validate that the ID must be a number).

Severity: High.

Priority: High.

#2)

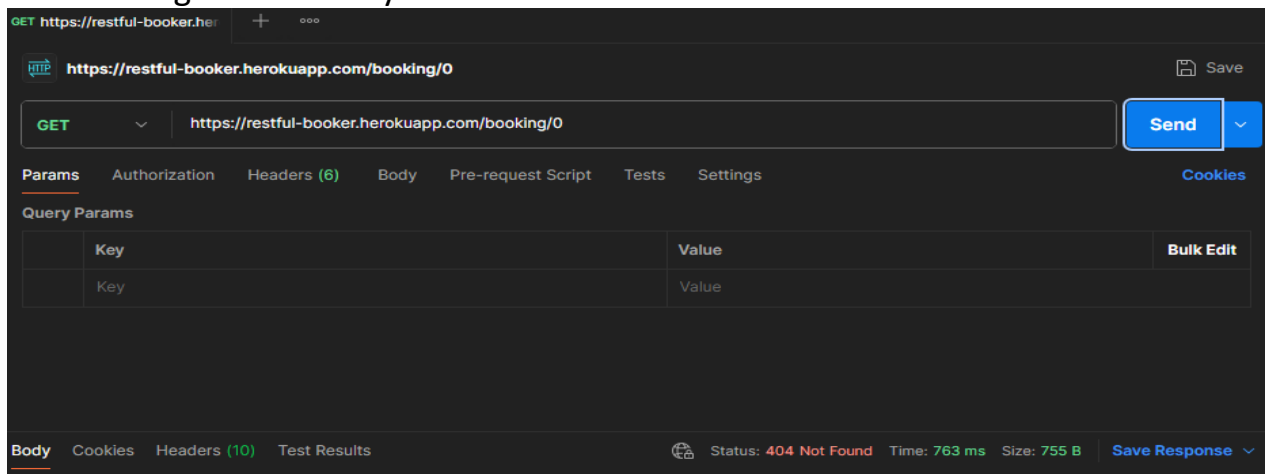
Title: Validate GetBooking API returns 404 Not Found when entering non-existing booking ID.

Steps:

- 1- Open Postman.
- 2- Set request method to GET.
- 3- Enter URL: <https://restful-booker.herokuapp.com/booking/99999999> (Use a very large number that doesn't exist).
- 4- Click on the Send button.

Description:

When I make a GET request to retrieve a booking with an ID that does not exist in the database (e.g., 99999999), the system should handle this gracefully. While it returns 404, it often lacks a clear error body or doesn't match the expected business logic for some systems.



Expected Result: API returns 404 Not Found with a clear message like "Booking not found".

Actual Result: API returns 404 Not Found but with a generic "Not Found" message or empty body.

Severity: High.

Priority: High.

#3)

Title: Validate GetBooking API returns 400 Bad Request when booking ID is negative.

Steps:

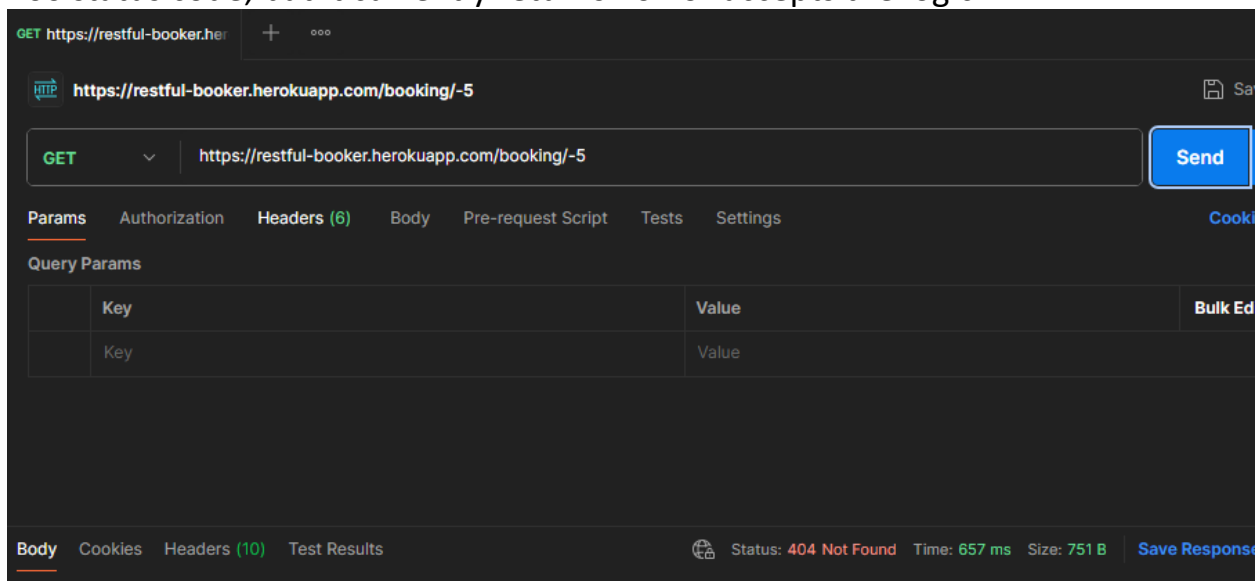
1- Open Postman.

2- Set method to GET.

3- Enter URL: `https://restful-booker.herokuapp.com/booking/-5`

4- Click on Send.

Description: The API should validate the ID input. When sending a negative number (e.g., -5), the system should not process the request and should return a 400 status code, but it currently returns 404 or accepts the logic.



Expected Result: API returns 400 Bad Request.

Actual Result: API returns 404 Not Found.

Severity: Medium.

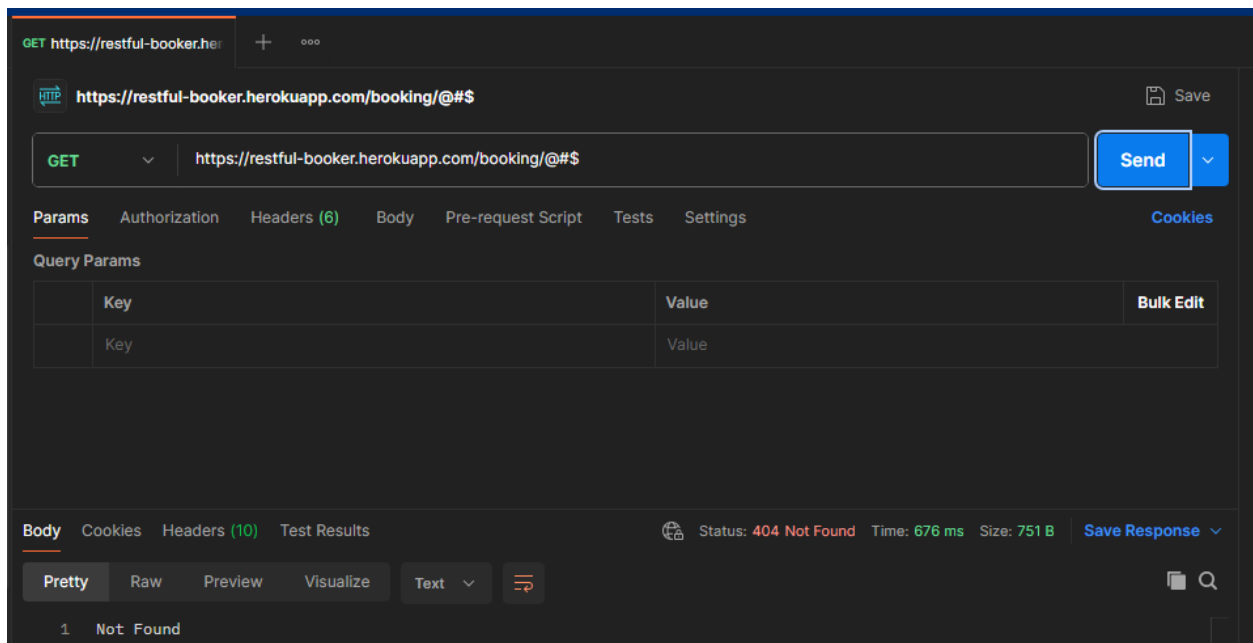
Priority: Medium.

#4)

Title : Booking ID contains special characters and returns incorrect status code.

Steps : 1- send GET /booking with ID : “ @#\$ ”.

Description : when I make GET request to test api , I entered special characters in booking ID field and the system return status code 404 instead of 400 Bad Request.



Expected Result : API returns 400 Bad Request.

Actual Result : API returns 404 Not Found.

Severity : medium.

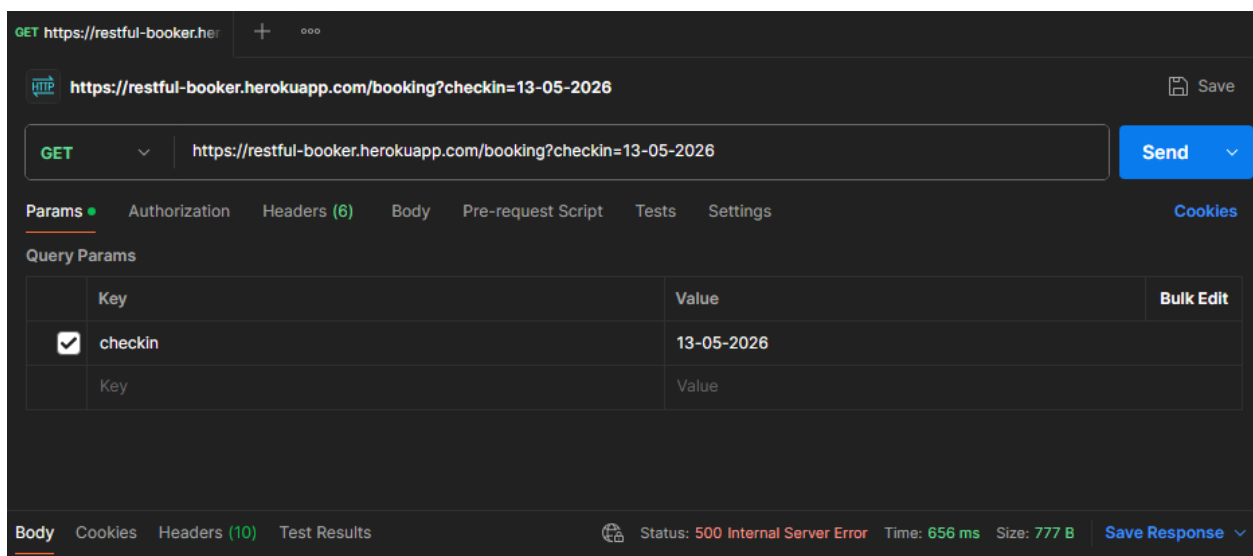
Priority : medium.

#5)

Title : GetBookingIds returns 500 Internal Server Error with invalid date format filtering.

Steps : 1- send GET /booking?checkin=13-05-2026.

Description : when I filter bookings by checkin date using an invalid format (DD-MM-YYYY), the system crashes and returns 500 Internal Server Error instead of 400 Bad Request.



Expected Result : API returns 400 Bad Request.

Actual Result : API returns 500 Internal Server Error.

Severity : High

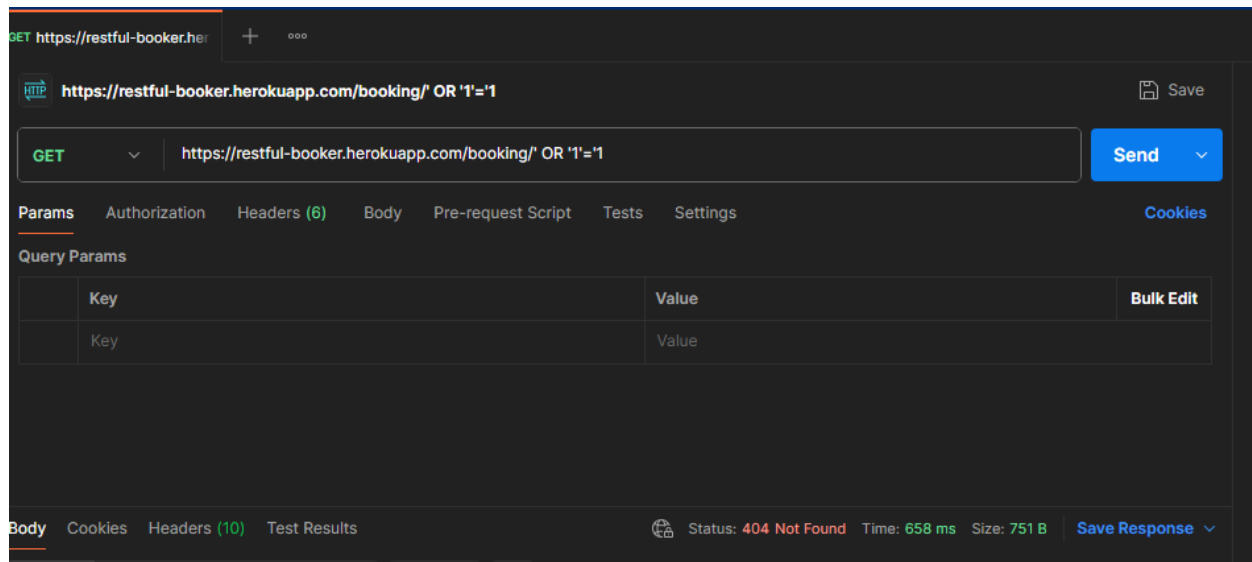
Priority : High

#6)

Title : SQL Injection vulnerability in Booking ID field.

Steps : 1- send GET /booking with ID : “ ' OR '1'='1 ”.

Description : when I test for SQL injection in the booking ID field, the system returns 500 Internal Server Error or 404 instead of properly validating and returning 400 Bad Request.



Expected Result : API returns 400 Bad Request.

Actual Result : API returns 404 Not Found (or 500).

Severity : High.

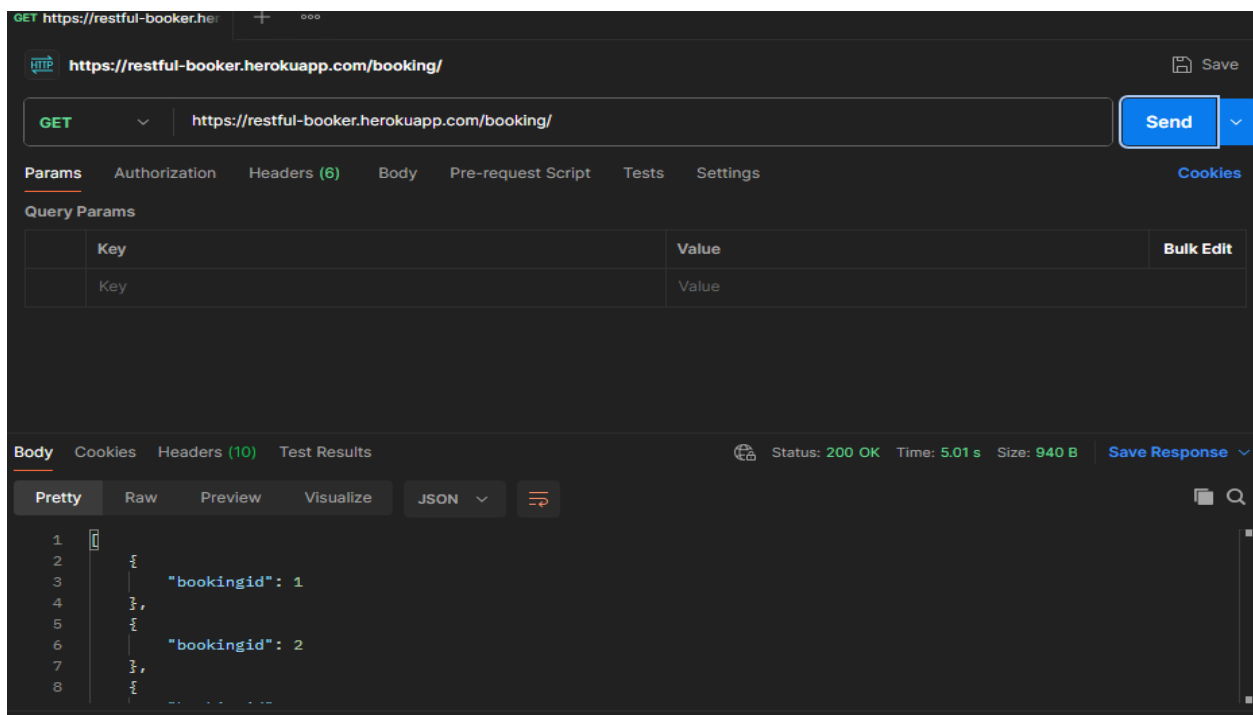
Priority : High.

#7)

Title : Sending GET request with empty booking ID returns all bookings instead of error.

Steps : 1- send GET /booking/ with empty ID value.

Description : when I make GET request to retrieve a specific booking and leave the ID field empty, the system returns status code 200 OK and a list of all booking IDs instead of returning 400 Bad Request.



Expected Result : API returns 400 Bad Request or a validation error.

Actual Result : API returns 200 OK and lists all available booking IDs.

Severity : Medium.

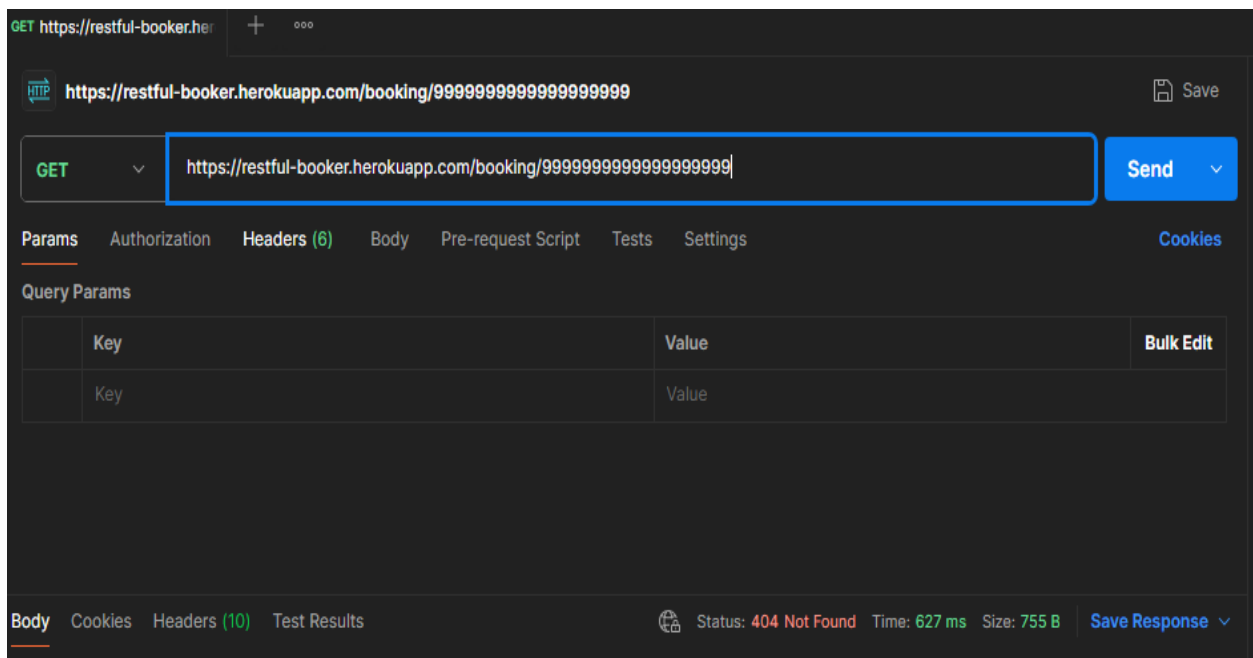
Priority : Medium.

#8)

Title : Extremely long booking ID handled incorrectly.

Steps : 1- send GET /booking with a very long numeric ID.

Description : when I enter an extremely long number in the booking ID field, the system returns 404 Not Found instead of validating the maximum length or returning 400 Bad Request.



Expected Result : API returns 400 Bad Request.

Actual Result : API returns 404 Not Found.

Severity : Medium.

Priority : Medium.

UPDATE BOOKING

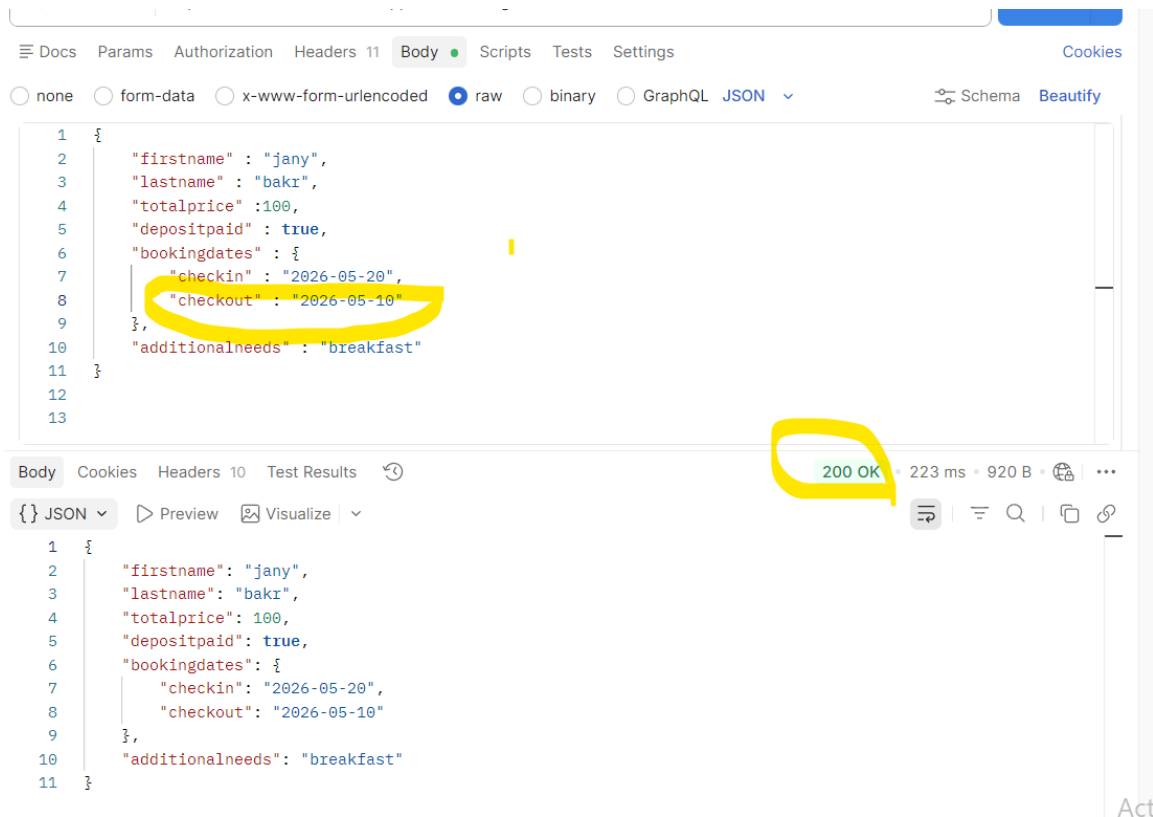
#1

Title: System accepts checkout date before check-in date in Update Booking.

Steps:

1- Send PUT /booking/{id} with checkout date earlier than check-in date.

Description: When I make a PUT request to update a booking, I set the checkout date to be before the check-in date, and the system accepts it and returns status code 200 OK.



Expected Result : API should return 400 Bad Request or a validation error.

Actual Result: API returns 200 OK and updates the booking with invalid dates.

Severity: High

Priority: High

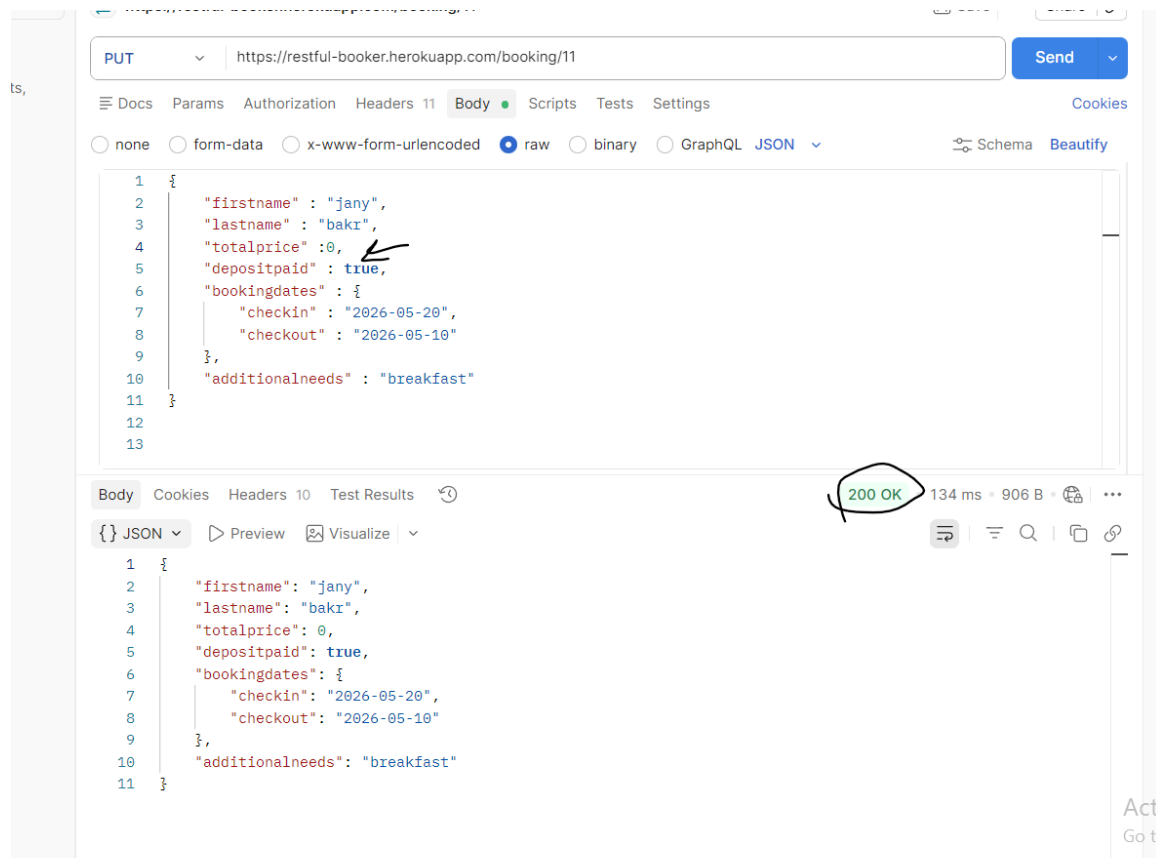
#2

Title: System accepts Total Price as zero (0) in Update Booking.

Steps:

1- Send PUT /booking/{id} with total price : 0.

Description: When I make a PUT request to update a booking, I set the total price field to 0, and the system accepts it and returns status code 200 OK



Expected Result : API should return 400 Bad Request as the price cannot be zero.

Actual Result: API returns 200 OK and creates a booking with 0 price.

Severity: High

Priority: Medium

#3

Title: System accepts numbers and symbols in First and Last name fields.

Steps:

1- Send PUT /booking/{id} with numbers in firstname and last name fields.

Description: When I make a PUT request to update a booking, I enter numbers like "12345" in the name fields, and the system accepts it and returns status code 200 OK

The screenshot shows a REST client interface with a PUT request to `https://restful-booker.herokuapp.com/booking/11`. The request body is a JSON object with the following fields: `firstname` (value: `"#123"`), `lastname` (value: `"baki"`), `totalprice` (value: `0`), `depositpaid` (value: `true`), `bookingdates` (an object with `checkin`: `"2026-05-20"` and `checkout`: `"2026-05-10"`), and `additionalneeds` (value: `"breakfast"`). The response status is `200 OK` with a response time of `823 ms` and a body size of `910 B`. The response body is a JSON object identical to the request body.

```
PUT https://restful-booker.herokuapp.com/booking/11

{
  "firstname": "#123",
  "lastname": "baki",
  "totalprice": 0,
  "depositpaid": true,
  "bookingdates": {
    "checkin": "2026-05-20",
    "checkout": "2026-05-10"
  },
  "additionalneeds": "breakfast"
}
```

200 OK • 823 ms • 910 B

```
{
  "firstname": "#123",
  "lastname": "baki",
  "totalprice": 0,
  "depositpaid": true,
  "bookingdates": {
    "checkin": "2026-05-20",
    "checkout": "2026-05-10"
  },
  "additionalneeds": "breakfast"
}
```

Expected Result: API should return 400 Bad Request (Names should only contain letters).

Actual Result: API returns 200 OK and updates the name with numeric values.

Severity: Medium

Priority: Medium

DELETE BOOKING

#1

Title: System accepts expired tokens

Steps:

- 1- Send POST request with username:"admin" and password:"password123" to get new token
- 2- Send Delete request with a valid booking ID
- 3- Send POST request again to change token
- 4- Send Delete request with a new booking ID with same token

Attachment:

1- Usage of token

The screenshot shows a REST client interface with a dark theme. At the top, it says "My Collection / New Request". There are buttons for "Save", "Share", and "Send". The URL bar contains "https://restful-booker.herokuapp.com/booking/1" and is circled in blue. Below the URL bar, there are tabs for "Docs", "Params", "Auth", "Headers (8)", "Body", "Scripts", and "Settings". The "Headers" tab is selected, showing a table with headers. The first header is "Cookie" with a value of "token: ffd8b215327249", which is also circled in blue. Below the headers, there is a "Body" section with a "Raw" tab selected. The response status is "201 Created", which is circled in blue. The response body shows "1 Created".

DELETE <https://restful-booker.herokuapp.com/booking/1> Send

Docs Params Auth **Headers (8)** Body Scripts Settings Cookies

Headers 7 hidden

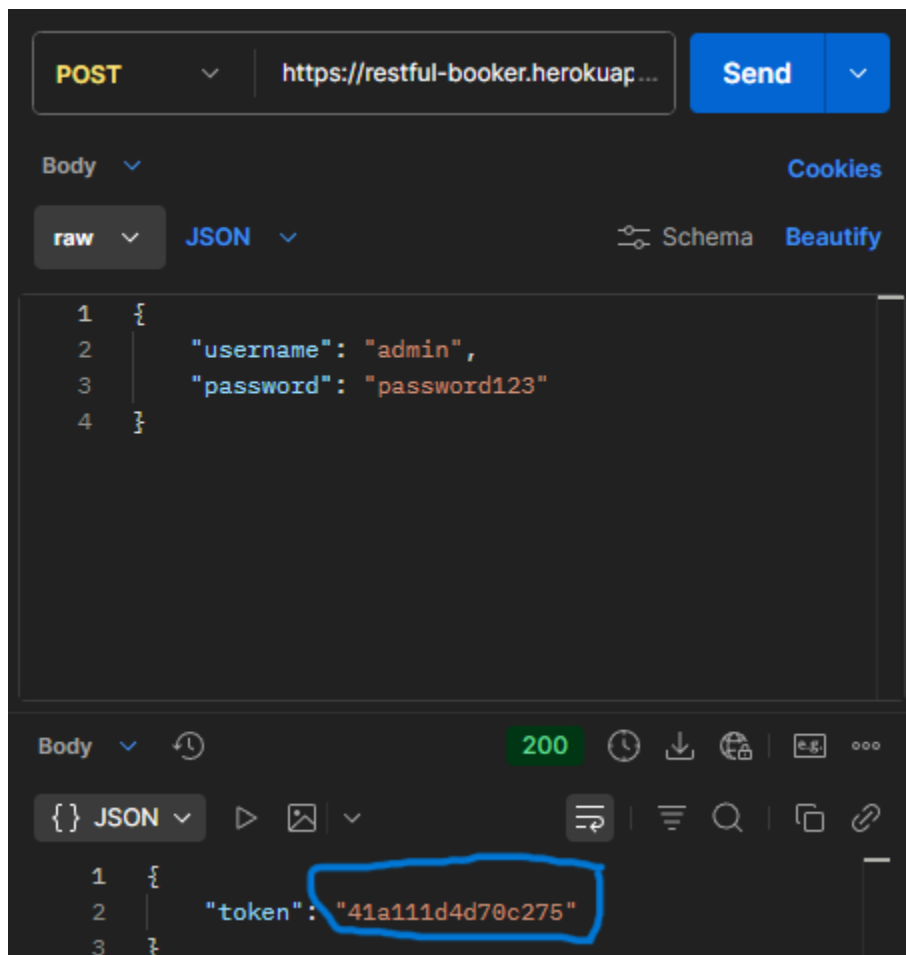
	Key	Value	Description
☒	Cookie	token: ffd8b215327249	
	Key	Value	Description

Body Raw Preview Visualize

201 Created 637 ms 747 B Save Response

1 Created

2- Creation of the new token



3- Successful booking deletion of an expired token

The screenshot shows a REST client interface with the following details:

- Method:** DELETE
- URL:** `https://restful-booker.herokuapp.com/bookings/2`
- Headers:** 8 headers are listed. The 'Cookie' header is checked and its value is `token=ffdf8b215327249`.
- Response:** The status is `201 Created` (highlighted with a red circle). The response time is 623 ms and the size is 743 B.
- Body:** The response body is `1 Created` (highlighted with a red line).

Description: When entering an expired token the system is supposed to reject an expired token booking deletion, however system accepts the token without showing any errors

Expected Result : API should return 400 Bad Request or 405 Forbidden for a validation error.

Actual Result: API returns 201 Created and deletes booking of an already expired token

Severity: High

Priority: High